# Identity & Access Management Security Control Assessment

*Current-State Gap Analysis, Findings, Remediation Roadmap & Verification Plan*

| Document identifier | Version | Review cut-off | Classification |
|---|---|---|---|
| **IAM-SAR-2026-001** | 1.0 / Portfolio | November 2, 2026 | PUBLIC — FULLY SYNTHETIC |

Fictional organization: Northstar Digital Services (invented name; no actual systems, customers, employees, or access rights examined).

Authoring purpose: showcase technical assessment writing, evidence-to-finding traceability, cyber risk decision-making, and implementation planning. NOT an independent audit, regulatory certification, authorization to operate, production assessment or proof of successful remediation.

## 1. Executive assessment and decision brief

Northstar Digital Services is a fictional 128-person cloud-enabled services organization using an identity provider (IdP), employee directory, SaaS CRM, cloud administration portal, developer repository, ticketing tool, and regulated-records sandbox. The assessment examines the identity lifecycle, authentication, access grants, privileged operations, auditability, nonhuman identities, and federation. A simulated control sample suggests material weaknesses in privilege recertification, joiner/mover/leaver handoffs, and phishing-resistant MFA coverage. No production systems were accessed or tested.

Overall assessment: ELEVATED RISK (illustrative qualitative judgment, not a scored NIST certification). Critical/High issues should be treated as implementation priorities subject to owner confirmation. Recommended decision: approve a 90-day remediation program, preserve evidence, validate administrator MFA controls, revoke orphaned entitlements after authorization, and establish repeatable access review governance. This is a recommended scenario decision; no real approval occurred.

### Decision summary

| Theme | Synthetic baseline | Recommended 90-day target |
|---|---|---|
| **Privileged phishing-resistant MFA** | 8 of 12 privileged accounts (67%) | 12/12 or documented approved exceptions |
| **All-user MFA enrollment** | 114 of 128 personnel (89%) | 128/128 in scope or formally risk-accepted exceptions |
| **Terminations tested** | 5 of 18 sampled exits late | 0 overdue among new exits with verified timing |
| **Stale/ownerless accounts** | 7 accounts require validation | 0 unowned active accounts |
| **Privileged access recertification** | 2 of 4 apps missing sign-off | 4/4 risk-scoped apps with signed review |

## 2. System, organization and assessment scope

The synthetic system boundary covers workforce access to the IdP, directory groups, SaaS CRM, ticketing service, cloud administration portal, source-control platform, and a controlled records application. HR is the authoritative joiner/mover/leaver trigger. Named reviewers are the IT identity lead, application owners, HR representative, Security GRC analyst, and Security Operations lead. External partners and vendor identities are reviewed only where explicitly modeled.

Out of scope: physical entry and badges; endpoint vulnerability assessment; network penetration testing; actual payroll and patient data; financial audits; legal interpretation of an actual company's obligations; real HIPAA/FDA coverage determination. The sample regulated-records application is hypothetical; including a related control does not establish that the company is a covered entity or regulated manufacturer.

## Assessment method and confidence

Procedure modeled on NIST SP 800-53A: examine available records, interview role owners, and test specified control behaviors where authorized. For this public portfolio, each “observed” result was constructed from synthetic CSV evidence. Evidence IDs link findings to records. The rating method is an illustrative qualitative matrix using likelihood and impact—not a published NIST scoring formula. Every remediation outcome initially remains OPEN / NOT TESTED.

## Synthetic evidence inventory

| Evidence ID | Artifact | Purpose |
|---|---|---|
| **EV-01** | Synthetic_Identity_Inventory.csv | Lifecycle, account status, identity type, ownership, MFA posture |
| **EV-02** | Synthetic_Access_Review_Sample.csv | Roles, entitlements, reviewer decision and evidence gaps |
| **EV-03** | Synthetic_Assessment_Observations.csv | Evidence-led observations for nine findings |
| **EV-04** | IAM_POAM_Register.csv | Ownership, action, due window, validation and closure criteria |
| **EV-05** | IAM_Control_Traceability.csv | Finding-to-NIST references and evidence limitations |

# 3. Current-state identity and system security architecture

HR event → identity administration queue → IdP/directory identity → group-driven application access; role-changing and termination signals trigger manual tickets. Some SaaS applications accept SSO; two use local accounts. Cloud administration uses named privileged accounts but not all have phishing-resistant MFA. Service accounts exist for data synchronizations and require documented owners, least-privilege entitlements, credential rotation and token validation.

## Current-state review by lifecycle phase

| Lifecycle or control | Current-state illustration | Principal exposure |
|---|---|---|
| **Joiner** | HR request creates access ticket; default groups assigned | Inconsistent role-to-group mapping and approval trace |
| **Mover** | Manager emails role changes; old roles may persist | Privilege accumulation and SoD conflict |
| **Leaver** | HR termination feed checked manually | Delayed access revocation |
| **Authentication** | MFA mixed by app; stronger methods limited for admins | Credential phishing/account takeover |
| **Privileged admin** | 12 elevated identities; periodic recertification inconsistent | Persistent excessive privilege |
| **Service/federation** | 10 service identities; token review not centrally recorded | Nonhuman credential and replay risks |
| **Monitoring** | Authentication logs kept in separate tools; no central review rule | Detection and investigation gaps |

# 4. Assessment criteria and risk methodology

The following publications provide assessment and control design references, not automatic legal obligations for a private fictional company: NIST CSF 2.0 Protect / Identity Management Authentication and Access Control (PR.AA), NIST SP 800-53 Rev. 5 Release 5.2.0, NIST SP 800-53A Release 5.2.0, NIST SP 800-63-4 family (2025), NIST SP 800-30 Rev. 1, CISA IAM best practices / Zero Trust Maturity Model, and NIST IR 8587 (September 2026) for tokens and assertions. The assessment does not claim the fictional company is FISMA-, FedRAMP-, HIPAA-, or FDA-regulated.

### Qualitative assessment rubric (scenario policy)

| Risk rating | Likelihood / impact interpretation | Action priority |
|---|---|---|
| **CRITICAL** | Credible exploit path plus severe business/safety exposure | Escalate immediately; emergency control with approvals |
| **HIGH** | Likely exploitation or substantial exposure; weak compensating controls | Owner assigned; plan within first 30 days |
| **MODERATE** | Plausible exposure with limited scope or mitigating controls | Scheduled remediation and verification |
| **LOW** | Minor documentation or marginal residual exposure | Track and address through routine change |

Risk acceptance is a formal management decision that records justification, expiry, residual risk and approver—not a substitute for evidence or completed remediation. Time windows in this report are fictional project targets, not mandatory federal deadlines.

## 5. Detailed findings: observed condition, cause, risk and corrective control

### F-01 | HIGH | Privileged MFA is not uniformly phishing resistant

Observed condition (synthetic): 8 of 12 privileged identities showed phishing-resistant MFA; four relied on weaker factors in the synthetic baseline (EV-01).

Why it matters: Attackers gaining reused or phished credentials may obtain elevated cloud access.

Action owner: Security + Identity. Recommended remediation: Inventory privilege-bearing paths; require phishing-resistant authenticators where supported; disable legacy fallback; set controlled break-glass exceptions; test sign-in logs.

Reference mapping (informative): NIST SP 800-63B-4; NIST SP 800-53 IA-2, AC-6; CSF PR.AA-03. Validation must document both the configured control and a test of expected behavior; status remains OPEN until independently reviewed.

### F-02 | HIGH | Leaver disablement is delayed

Observed condition (synthetic): 5 of 18 completed termination tickets in the sample lacked evidence of access removal by the approved company target (EV-03).

Why it matters: Former-worker access may remain viable after separation.

Action owner: HR Operations + IAM. Recommended remediation: Integrate authoritative HR feed; correlate identities across SaaS/local accounts; define and test disablement automation, exception alerts and escalation.

Reference mapping (informative): NIST SP 800-53 AC-2, PS-4; CSF PR.AA-01, PR.AA-05. Validation must document both the configured control and a test of expected behavior; status remains OPEN until independently reviewed.

### F-03 | HIGH | Excessive privileges and separation-of-duties conflicts

Observed condition (synthetic): Nine sampled user-to-role combinations include permissions beyond the sample role matrix; two could both request and approve records (EV-02).

Why it matters: Unauthorized changes, errors, or fraudulent approval are harder to prevent.

Action owner: Business Application Owners. Recommended remediation: Build entitlement catalogue and SoD rules; require manager/application-owner attestation; remove approved extras; verify denied access and preserve audit trail.

Reference mapping (informative): NIST SP 800-53 AC-3, AC-5, AC-6; CSF PR.AA-05. Validation must document both the configured control and a test of expected behavior; status remains OPEN until independently reviewed.

## F-04 | MODERATE | Orphaned and unowned accounts

Observed condition (synthetic): Seven active identities have absent or uncertain business owners in the fictional inventory (EV-01).

Why it matters: Unaccountable credentials increase persistence and misuse risk.

Action owner: IAM + System Owners. Recommended remediation: Classify human/nonhuman identities; validate dependencies; block unauthorized login where safe; reassign documented owners or deprovision via change control.

Reference mapping (informative): NIST SP 800-53 AC-2, IA-4; CSF PR.AA-01. Validation must document both the configured control and a test of expected behavior; status remains OPEN until independently reviewed.

## F-05 | MODERATE | Application recertification lacks approvals

Observed condition (synthetic): Two of four selected business-critical applications do not contain dated owner sign-offs for the last simulated review (EV-02).

Why it matters: Inappropriate access can persist without independent review.

Action owner: GRC + App Owners. Recommended remediation: Define risk-based review cadence; export complete entitlements; require disposition of exceptions and second-person verification for elevated rights.

Reference mapping (informative): NIST SP 800-53 AC-2, AC-6, CA-7; CSF PR.AA-05. Validation must document both the configured control and a test of expected behavior; status remains OPEN until independently reviewed.

## F-06 | HIGH | Service identities and API tokens lack unified safeguards

Observed condition (synthetic): Three of ten synthetic nonhuman identities lack rotation evidence; token issuer/audience validation requirements are undocumented for one integration (EV-03).

Why it matters: Leaked or mis-scoped service credentials can enable unauthorized API access.

Action owner: Platform Engineering + Security. Recommended remediation: Inventory credentials, owners and scopes; migrate where feasible to managed workload identities; limit token lifetime; enforce signature/issuer/audience checks; plan key rotation.

Reference mapping (informative): NIST IR 8587 (2026); SP 800-63C-4; AC-6, IA-5. Validation must document both the configured control and a test of expected behavior; status remains OPEN until independently reviewed.

## F-07 | MODERATE | Inadequate centralized authentication event review

Observed condition (synthetic): Events remain in multiple systems; no documented correlation for disabled-account sign-ins or privileged role changes (EV-03).

Why it matters: Security team may miss account misuse or be unable to reconstruct an event.

Action owner: Security Operations. Recommended remediation: Specify minimum event fields, UTC timestamp consistency, access restrictions, retention per risk/obligations; route alerts to monitored case queue and test detection.

Reference mapping (informative): NIST SP 800-53 AU-2, AU-6, AU-12, SI-4; CSF DE.CM. Validation must document both the configured control and a test of expected behavior; status remains OPEN until independently reviewed.

## F-08 | MODERATE | Exception and break-glass accounts are not governed consistently

Observed condition (synthetic): Two emergency accounts lack a current owner-review record; test-use and post-use review are not documented (EV-03).

Why it matters: Emergency credentials may become permanent unmonitored privileged pathways.

Action owner: Security + IT Operations. Recommended remediation: Define vault/access control, monitored emergency use, tested recovery, documented expiry and after-action approval without making recovery dependent on a failed IdP.

Reference mapping (informative): NIST SP 800-53 AC-2, AC-6, IA-5; CSF PR.AA-03. Validation must document both the configured control and a test of expected behavior; status remains OPEN until independently reviewed.

### F-09 | MODERATE | Joiner and mover approvals lack role-change evidence

Observed condition (synthetic): Three of twelve sample role changes lack a clear old-role removal decision and signed request justification (EV-03).

Why it matters: Entitlements accumulate through transfers, undermining least privilege.

Action owner: HR + Managers + IAM. Recommended remediation: Standardize role catalog, ticket data fields, authoritative approvals and automatic old-role review; implement evidence-linked joiner/mover/leaver checklist.

Reference mapping (informative): NIST SP 800-53 AC-2, AC-6, PS-5; CSF PR.AA-01, PR.AA-05. Validation must document both the configured control and a test of expected behavior; status remains OPEN until independently reviewed.

## 6. Target-state security design and remediation roadmap

Proposed target state: authoritative HR-driven identity lifecycle; IdP-based SSO where appropriate; risk-based, phishing-resistant MFA for high-impact access; centrally managed entitlements; strong privilege separation; controlled break-glass; reviewed nonhuman identities and token practices; monitored identity events; and accountable periodic access reviews.

### Phased implementation

| Phase | Activities | Gate / deliverable |
|---|---|---|
| **0–15 days** | Confirm system boundary and application owners; suspend unauthorized access through approved process; review privileged MFA and immediate leaver exposures. | Signed inventory; approved immediate risk responses; evidence preserved |
| **16–30 days** | Configure phishing-resistant privileged MFA; establish termination workflow; risk-rank orphaned identities; write access-review SOP. | Pilot evidence for admin sign-ins and identity disablement |
| **31–60 days** | Remediate excessive grants; integrate SaaS/local account exception inventory; centralize identity log alerts; secure service tokens. | Control configuration record, sampled UAT and updated POA&M |
| **61–90 days** | Run manager/app-owner access attestation; execute leaver and mover negative tests; evaluate residual risk; repeat metric baseline. | Reviewer-approved evidence package and explicit open findings |

### Responsibility and change governance

RACI: Identity Lead is accountable for technical provisioning rules; HR owns employee status and effective times; each Application Owner owns entitlement justification; Security GRC maintains the findings and evidence register; Security Operations owns detection and triage; independent approver accepts residual risk. Changes affecting authentication must have backout plans, pilot users, emergency recovery paths, and user communications. Critical access removals are controlled and recorded, never performed merely to make the scenario data look cleaner.

## 7. Validation procedures and acceptance criteria

| Test | Evidence/action | Pass criteria |
|---|---|---|
| **V-01 / F-01** | For each privileged account, inspect authentication policy + allowed factors, | 12/12 require phishing-resistant authentication or documented, time- |

| | | |
|---|---|---|
| | then execute approved sign-in test and attempt legacy fallback. | limited exception; emergency route separately controlled. |
| **V-02 / F-02** | Using test HR termination event, inspect IdP, cloud, CRM and local-app account disposition; measure elapsed time using timestamps. | All scoped access revoked within approved company SLA; no lingering SSO or local sessions outside documented exception. |
| **V-03 / F-03** | Select representative roles; review manager approval and verify unauthorized action is blocked in test environment. | No unacceptable SoD conflicts; removal reflected in authoritative export and negative-access test. |
| **V-04 / F-04** | Reconcile all accounts with sponsor and directory; check service dependency and owner sign-off. | No active orphaned account lacking a designated owner and approved justification. |
| **V-05 / F-05** | Export permissions for four high-risk apps and obtain owner attestations with disposition logs. | 4/4 reviews signed; access changes verified, exceptions tracked. |
| **V-06 / F-06** | Examine service-token audience, issuer, key/secret storage, expiry, logging and rotation evidence; run synthetic invalid-token tests. | Token verification rejects invalid issuer/audience/signature and evidence reflects owner-controlled rotation. |
| **V-07 / F-07** | Create simulated login failure, disabled-user attempt and privilege-change records; check correlation and alert routing. | All defined test events captured with timestamps, owner and monitored alert route. |
| **V-08 / F-08** | Review break-glass vault controls, owner list and exercise log; rehearse recovery within approved isolated test. | Authorized recovery works; use generates reviewable evidence; routine access remains restricted. |
| **V-09 / F-09** | Run new hire and role transfer examples through approved requests, approvals and entitlement comparison. | Access corresponds to target role; previous entitlements expressly reviewed and removed or justified. |

Testing status: NOT EXECUTED. These are proposed acceptance tests. A real reviewer would record operator, system/environment, timestamp, expected/actual result, defect link and evidence location. Do not write PASSED without actual execution.

## 8. Continuous monitoring and success metrics

Metrics must be measured repeatedly with a stable denominator. Track: privileged phishing-resistant MFA coverage; overall required MFA coverage; leaver deprovisioning SLA compliance; orphaned identities; access-review completion; aged access exceptions; privileged account count and stale role memberships; service identity owner coverage; token/key rotation exceptions; and tested identity-alert detection rate. Report thresholds are scenario objectives, not NIST universal mandates.

| Metric | Synthetic baseline | Calculation / evidence | Review |
|---|---|---|---|
| **Admin phishing-resistant MFA** | 8/12 = 66.7% | Verified strong-factor privileged identities / total privileged | Weekly until controlled |
| **Workforce MFA coverage** | 114/128 = 89.1% | In-scope MFA-enrolled people / all scoped people | Weekly |
| **Late deprovisioned exits** | 5/18 = 27.8% | Late sampled exits / scoped exit sample | Per termination + monthly |
| **Unowned active accounts** | 7 | Unowned accounts still enabled after reconciliation | Weekly |
| **Approval completeness** | 2/4 applications | Apps with signed and dated entitlement reviews / selected apps | Quarterly or risk-based |

## 9. Exceptions, residual risk, and management decisions

Each exception must identify the business need, impacted control, alternative safeguards, requester, accountable approver, start and expiry date, review date, and evidence. A finding is not CLOSED solely because a ticket was opened, a configuration was changed, or a policy was drafted. Close only after the planned verification procedure succeeds and an authorized reviewer accepts the evidence. Open exceptions remain visible in the POA&M.

Example risk decision: An emergency administrator account remains available for directory outage recovery, but must be isolated from day-to-day use, strongly protected, monitored, tested through a separate recovery route, and subject to post-use review. Its exemption from routine enforcement must be formally documented and time-bound as appropriate to company risk policy.

## 10. Legal applicability and publication boundaries

NIST publications and CISA resources are authoritative guidance and references, but ordinarily not independently binding law on all private companies. FISMA and FedRAMP would be relevant only if a real system fell into those programs; the term POA&M is used here as an industry-style remediation register, not a FedRAMP authorization package. HIPAA safeguards (45 CFR 164.308 and 164.312) would require a real covered-entity/business-associate determination and ePHI scope. FDA Part 11 depends on qualifying electronic records/signatures and underlying predicate rules; this fictional IAM assessment cannot claim such scope. State breach notification/privacy obligations likewise depend on actual state and data context.

This model omits the secrets, real IP ranges, actual user lists, exploit details, credentials, service endpoints, and environmental security configurations required in a real internal report. All identities, findings, timestamps, numbers and evidence IDs are invented. An independent technical and legal reviewer would scope any real application.

## 11. Reference register — primary federal sources


NIST CSF 2.0 PR.AA — https://www.nist.gov/cyberframework

NIST SP 800-53 Rev. 5, Release 5.2.0 (Aug 2025) — https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

NIST SP 800-53A Rev. 5, Release 5.2.0 — https://csrc.nist.gov/pubs/sp/800/53/a/r5/final

NIST SP 800-63-4 digital identity (July 2025; hub Oct 2026) — https://csrc.nist.gov/pubs/sp/800/63/4/final

NIST SP 800-63B-4 authentication — https://csrc.nist.gov/pubs/sp/800/63/b/4/final

NIST SP 800-63C-4 federation — https://csrc.nist.gov/pubs/sp/800/63/c/4/final

NIST IR 8587 tokens and assertions (Sept 2026) — https://csrc.nist.gov/pubs/ir/8587/final

NIST SP 800-30 Rev. 1 risk assessment — https://csrc.nist.gov/pubs/sp/800/30/r1/final

CISA IAM recommended practices — https://www.cisa.gov/sites/default/files/2023-12/ESF%20IDENTITY%20AND%20ACCESS%20MANAGEMENT%20RECOMMENDED%20BEST%20PRACTICES%20FOR%20ADMINISTRATORS%20PP-23-0248_508C.pdf

CISA Zero Trust Maturity Model 2.0 — https://www.cisa.gov/zero-trust-maturity-model

HHS HIPAA Security Rule overview (conditional) — https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html

FedRAMP 2026 POA&M handling (conditional) — https://www.fedramp.gov/2026/agencies/use/ongoing/poams/


Reference verification date: November 2, 2026. Guidance and agency pages may be revised; refresh applicability and citation before real-world use. Proprietary standards not accessed in full are not presented as audited.

## Appendix A. Sample observation-to-closure narrative

Example F-02: HR sample file shows a fictional individual separated on October 8 at 17:00, but the local CRM entitlement stayed enabled until October 10 at 12:00. Reviewer checks original record timestamps and HR authorization before concluding whether a target was missed. The root-cause hypothesis is a manual handoff gap; it must be validated by process review rather than assumed. Corrective approach: integrate status events, verify both cloud and local account deactivation, retry failure queue, and audit a later sample. Closure requires new event test evidence; the status remains OPEN in this portfolio.

## Appendix B. Editorial QA and completeness checklist

- All findings include ID, severity, synthetic evidence reference, risk, owner, recommended remediation and verification route.
- Every KPI distinguishes numerator, denominator, period and hypothetical status; no fabricated achievements are represented as real outcomes.
- No invented numerical deadline is attributed to NIST, FDA, HIPAA, FedRAMP, or CISA.
- Design remains readable in monochrome: dark blue headings, black body, text severity labels, no color-only information.
- No PII, real vendor names, credentials, personal account data, or employer confidential records.
- Links and references are documented and relevant to assessment scope; optional guidance remains optional.
- Release label remains PUBLIC SYNTHETIC / NO AUTHORIZED APPROVAL; report is not an actual independent audit.

## Appendix C. Microsoft Teams external-contact incident: access-control assessment

Assessment status: SYNTHETIC INCIDENT; illustrative evidence only. This exercise models a social-engineering attack against a fictional business. No employee was actually contacted, no systems were examined, and no malware was deployed. The term “backdoor” refers here to a hypothesized persistence mechanism, not a feature created by an external Teams call.

### C.1 Scope, threat model and responsible systems

Fictional environment: Northstar Digital Services uses Microsoft Teams for collaboration, Microsoft Entra ID for identity and Conditional Access, Intune/Defender for managed Windows 11 endpoints, SharePoint/OneDrive for documents, a cloud CRM for customer operations, a mock enterprise ERP, and a support ticket platform. The assessment concerns external Teams federation, screen-sharing/remote assistance, identity assurance, endpoint response and downstream business-application exposure.

Threat: an external actor impersonates the internal help desk through a Teams chat or call (voice phishing / vishing). A user may then approve a screen-control request in a Teams meeting or start a separate remote-assistance session such as Quick Assist. External Teams communication alone does not confer device control or imply compromise. A persistent implant requires an additional malicious action and should not be asserted without appropriate endpoint evidence.

### C.2 Simulated timeline and evidence confidence

| Time (synthetic) | Observed or reported event | Evidence and confidence |
|---|---|---|
| **09:12** | Unrecognized external Teams account contacts employee as “IT Support.” | TEAMS-01 external-interaction metadata; simulated, high for contact only |
| **09:16** | Employee accepts a call and screen-shares following an urgent “account repair” request. | TEAMS-02 meeting metadata plus employee interview; simulated, medium |
| **09:19** | Employee grants control during a permitted meeting session, or launches Quick Assist at caller direction. | ENDPT-01 remote-session log; hypothetical branch; verification required |
| **09:24** | Endpoint security telemetry shows unapproved installer activity and a suspicious persistence alert. | EDR-01 fictional detection; suspect compromise, not established solely by call |
| **09:28** | Cloud sign-in log includes unusual session behavior and a new application-consent event. | ENTRA-01 fictional audit signal; requires independent correlation |
| **09:35** | SOC triages case, initiates containment and preserves original evidence. | CASE-01 response record; illustrative only |

The scenario models a credible attack chain described in Microsoft Security’s September 2026 research. Because no actual logs exist here, every timestamp and observation is invented, and the correct editorial language is “simulated indicators consistent with attempted persistence” rather than a conclusively verified production backdoor.

### C.3 Current-state configuration gaps and root-cause hypotheses

| Finding / priority | Current-state simulated condition | Impact / validation needed |
|---|---|---|
| **F-10 HIGH: Teams external contact** | Federation accepts all external domains; inbound unfamiliar contact is not governed by an approved business allowlist. | Impersonation exposure; review actual policy scope, legitimate external collaboration dependencies. |
| **F-11 HIGH: screen control / remote assistance** | External meeting control allowed for at least one organizer policy; Quick Assist is available without approved help-desk | Risk of interactive access after social engineering; verify policy precedence, exceptions and endpoint restrictions. |

| | | |
|---|---|---|
| | verification. | |
| **F-12 HIGH: endpoint persistence exposure** | Endpoint application controls and remote-support restrictions lack documented enforcement; suspicious installer alert is untriaged. | Potential unapproved executable persistence; forensic collection and incident-response scoping required. |
| **F-13 HIGH: IdP session and consent risk** | Privileged authentication coverage is inconsistent; risky session, app-consent and token-revocation playbooks untested. | Possible credential, session or OAuth abuse; investigate actual sign-in and consent evidence. |
| **F-14 MODERATE: response training** | Employees lack a defined out-of-band identity verification step for unsolicited "IT support" Teams contacts. | Users may comply with spoofed help-desk requests; scenario-based drills and escalation are needed. |

## C.4 Response decision tree: confirmed, suspected or disproved

- Upon a report, preserve the Teams invitation/chat identifiers, participant metadata, employee account details, remote-session artifacts and immutable alert records according to company retention and privacy policy.
- If an unauthorized interactive session is active, SOC and IT coordinate authorized containment; disconnect the session and isolate the endpoint using approved response tooling while retaining evidence needed for investigation.
- Do not assume "malware/backdoor installed" from a Teams call alone. Correlate EDR process ancestry, persistence indicators, signed-in sessions, application consent, file hashes and forensic results before classifying outcome.
- If compromise is credible, use documented endpoint eradication and recovery procedures; reimage if justified by incident response, and revoke relevant sessions/tokens and reset affected credentials with identity-team approval.
- Determine whether SharePoint/CRM/ERP access, sensitive records or regulated data were actually exposed; engage Legal/Privacy/QA based on evidence and applicable data scope.
- Document findings that contradict the hypothesis; classify as blocked attempt, unauthorized remote session without persistence, or confirmed compromise as evidence supports.

## C.5 Phased controls and configuration review plan

| Workstream / change owner | Proposed controlled change | Evidence of verification |
|---|---|---|
| **Teams Administrator** | Review Teams Admin Center > Users > External access. Move appropriate users to a business-justified approved-domain policy or restrict external contacts where feasible; maintain exception list. | Approved policy export, pilot test with allowed and blocked synthetic domains, rollback record. |
| **Teams Administrator** | Review Meetings > Meeting policies > Content sharing. Set external participant give/request control to Off for general-use policies; assess per-user "participants can give/request control" and meeting organizer options separately. | Policy-assignment evidence, test organizer/participant scenarios, no unexpected loss of legitimate accessibility use. |
| **Endpoint Engineering** | Restrict unapproved remote support and remote-management tools through application control and documented IT helpdesk support process; test managed support alternatives. | Controlled endpoint configuration, test cases for blocked unapproved and allowed approved support. |
| **Identity Security** | Apply phishing-resistant MFA to privileged roles, risk-informed Conditional Access, consent governance, least privilege and token/session | Entra policy scope, test accounts, break-glass exclusions reviewed, simulated risky session response evidence. |

| | | |
|---|---|---|
| | investigation playbooks. | |
| **SOC / Incident Response** | Alert on suspicious Teams-triggered remote support, remote tooling invocation, unauthorized installation, persistence indicators and unusual sign-ins; route alerts to analysts. | SIEM analytic test records, false-positive evaluation, ticket IDs, response-drill signoff. |
| **Support Leadership / Training** | Publish authentic IT support verification policy and "never grant unsolicited remote control" guidance; instruct employees to verify through known internal directory or ticket channel. | Training receipt, tabletop exercise result, anonymous customer-helpdesk scenario QA review. |

Policy changes are recommendations only; avoid deploying blanket external-access blocks without assessing approved customer/vendor collaboration, accessibility, international support, break-glass continuity, licensing, and change-management requirements.

## C.6 Threat-specific acceptance tests and success criteria

| Test ID | Scenario | Pass condition / expected evidence |
|---|---|---|
| **TEAMS-T01** | Synthetic unknown external tenant initiates contact under affected user policy. | Contact is restricted according to approved policy; policy/exception evidence captured. |
| **TEAMS-T02** | Approved business partner attempts an authorized Teams conversation. | Authorized communications still work and are logged without granting unneeded resource access. |
| **TEAMS-T03** | External attendee attempts screen-control in meeting organized by normal user. | External give/request control unavailable under assigned organizer policy, documented test result. |
| **ENDPT-T04** | Simulated unauthorized remote-help invocation. | Endpoint policy blocks unapproved tool while approved helpdesk workflow remains usable. |
| **SOC-T05** | Inject sanitized log fixture mimicking unsolicited helpdesk call plus remote session. | Detection fires, evidence is captured, analyst escalation meets fictional service goal. |
| **ID-T06** | Synthetic unusual admin sign-in and revoked-session exercise. | MFA/risk policy applies to scoped accounts; response workflow confirms revocation and audit trail. |
| **DRILL-T07** | Employee receives simulated "urgent security update" contact. | Employee verifies request through an established internal contact channel and reports it. |

All acceptance criteria are proposed—not executed. Findings F-10 through F-14 remain OPEN / NOT TESTED. No "100% protection" claim is supported by a configuration test.

## C.7 Teams-specific distinction: external access, guest access, remote control

External access (federation) enables chat/calls with outside organizations when configured; it does not itself add them to SharePoint sites, internal teams or tenant resources. Guest access and Entra B2B invitations are a separate control plane. Meeting-policy participant control and external participant control are also separate from remote assistance through Quick Assist or another approved support tool. Controls should be reviewed in all relevant administrative locations, not described as a single "Turn Teams Off" switch.

## C.8 Regulatory and standards mapping for this incident

| Source | Scope / why relevant | Status in this fictional company |
|---|---|---|
| **NIST SP 800-53 Rev. 5** | AC-2/AC-3; IA-2; AU-2/AU-6; IR-4; SI-3/SI-4; CM-7; AT-2—identity, logging, | Voluntary control mapping; not a certification. |

| | | |
|---|---|---|
| | response and system controls. | |
| **NIST CSF 2.0 / SP 800-63-4 / IR 8587** | Govern, protect, detect, respond and recover; authentication/federation; token and assertion safeguards. | Guidance-based assessment mapping. |
| **CISA/FBI/HHS joint alert AA24-131A and Microsoft 2026 research** | Documents Teams/remote-assistance social engineering and defensive priorities. | Threat intelligence and product guidance, not regulation. |
| **FDA 21 CFR Part 11** | Potentially relevant only to qualifying electronic records and signatures under applicable predicate rules. | Scope unestablished; do not claim it requires Teams configuration. |
| **FDA 21 CFR Parts 210/211 and ICH Q9/Q10** | May govern regulated pharmaceutical quality records and assessed impact when specific manufacturing operations are in scope. | No manufacturing evidence in this fictional case; conditional reference only. |
| **HIPAA Security Rule / state privacy laws** | May require risk analysis, safeguards or notification if applicable data and entity conditions are met. | No covered-entity, ePHI or state jurisdiction is asserted. |
| **FDA QMSR / 21 CFR Part 820** | Device manufacturing rule effective Feb 2026; distinct from drug CGMP. | Not assumed applicable. |
| **IEC 62443 / ISO 27001 / ISO 27002** | Useful frameworks for specialized industrial, ISMS or control contexts, if appropriately scoped. | Not audited against copyrighted texts or claimed certified. |

## C.9 Primary evidence-based references (verified November 2, 2026)


Microsoft 2026 Teams social engineering research — https://www.microsoft.com/en-us/security/blog/2026/09/02/impersonating-it-support-threat-actors-turn-remote-session-into-enterprise-wide-access/

Microsoft Teams external collaboration administration — https://learn.microsoft.com/en-us/microsoftteams/trusted-organizations-external-meetings-chat

Microsoft Teams presentation/request-control meeting policy — https://learn.microsoft.com/en-us/microsoftteams/meeting-who-present-request-control

Microsoft Defender for Office 365 Teams attack-surface guide — https://learn.microsoft.com/en-us/defender-office-365/step-by-step-guides/reducing-attack-surface-in-microsoft-teams

Microsoft Entra phishing-resistant MFA for administrators — https://learn.microsoft.com/en-us/entra/identity/conditional-access/how-to-policy-phish-resistant-admin-mfa

CISA/FBI/HHS Joint Alert AA24-131A Black Basta — https://www.cisa.gov/sites/default/files/2024-11/aa24-131a-joint-csa-stopransomware-black-basta_3.pdf

NIST SP 800-63-4 — https://csrc.nist.gov/pubs/sp/800/63/4/final

NIST IR 8587 (2026) — https://csrc.nist.gov/pubs/ir/8587/final

## Independent second-pass document review | November 2, 2026

REVIEWED PORTFOLIO DEMONSTRATION — this appendix records a document-specific editorial and source-scope check. The main procedure and forms are fictional and not approved for production, executed testing or regulated use. Original source versions are retained as editable files in this portfolio.

## A. Document-specific findings and checks

| Review objective | 2026 reviewer correction / expectation | Verification evidence |
|---|---|---|
| **Teams threat chain** | External Teams contact -> impersonation -> user-approved screen control or remote assistance -> separate suspicious process/consent -> possible persistence. | Calls alone cannot give computer control; classify compromise as suspected unless correlated EDR/IdP evidence verifies it. |
| **Review multiple systems** | Cover Teams external access and control, Entra MFA/role access, Windows endpoint remote tools, SharePoint sharing, CRM/ERP approval roles and support ticket verification. | Each finding has an owner, risk, evidence, proposed corrective measure and acceptance test. |
| **Current federal guidance** | NIST CSF 2.0, NIST SP 800-53/53A 5.2.0, SP 800-63-4, SP 800-61r3 and Microsoft Teams admin docs. | NIST frameworks recommendations rather than universal statutory mandates; FDA Part 11 only if regulated electronic records are in scope. |
| **Remediation proof** | POA&M actions require configuration exports, controlled pilot tests, logs and incident response exercises. | All evidence fictional; all remediation listed proposed / not executed. |

## B. Applicable regulatory / guidance boundaries

| Review objective | 2026 reviewer correction / expectation | Verification evidence |
|---|---|---|
| **NIST** | NIST CSF 2.0; SP 800-53 and 800-53A Release 5.2.0; SP 800-63-4; SP 800-61 Rev. 3. | Applicable as selected risk-management references; not mandatory for all private businesses. |
| **Microsoft Teams** | External federation, guest sharing, meeting-control and approved remote-assistance settings are distinct policies. | Verify policy precedence and role assignment before implementing any changes. |
| **Regulated systems** | FDA 21 CFR Part 11 and applicable CGMP requirements only if covered electronic records/predicate rules are relevant. | HIPAA or device QMSR must not be assumed for a generic company. |

## C. Evidence and sign-off boundaries

Status: Editorial second-pass reviewed; technical procedure not executed; company-specific SOP approval not obtained.

All tests, screenshots, users, suppliers, dates, IDs, incident observations, performance metrics and signatures in the demonstration are synthetic.

Next practitioner action: confirm source applicability for the actual jurisdiction and product; conduct SME/user testing and accessibility review; update controlled revision and approval fields.

No color, watermark, revision number, PDF export or reference link by itself demonstrates regulatory compliance.

## D. Authoritative primary-source references

NIST CSF 2.0: https://www.nist.gov/cyberframework

NIST 800-53 release 5.2.0: https://csrc.nist.gov/News/2025/nist-releases-revision-to-sp-800-53-controls

NIST 800-53A release 5.2.0: https://csrc.nist.gov/pubs/sp/800/53/a/r5/final

NIST 800-63-4: https://csrc.nist.gov/pubs/sp/800/63/4/final

NIST 800-61r3: https://csrc.nist.gov/pubs/sp/800/61/r3/final

Microsoft Teams external access: https://learn.microsoft.com/en-us/microsoftteams/trusted-organizations-external-meetings-chat

Microsoft Teams remote control: https://learn.microsoft.com/en-us/microsoftteams/meeting-who-present-request-control

FDA 21 CFR Part 11 scope: https://www.fda.gov/regulatory-information/search-fda-guidance-documents/part-11-electronic-records-electronic-signatures-scope-and-application